Lezing KPMG Samenvatting

Introductie
Het bedrijf KPMG biedt een heel breed scala aan diensten aan; die als consultancy omschreven kunnen worden. Eén van de categorieën waarin ze advies aanbieden is de cybersecurity. Deze tak telt ongeveer 50 mensen(geschat aan de getoonde foto), die hier vertegenwoordigd worden door Pieter en Iris.

CIA
Er bestaat een theoretisch kader dat principes bevat die omschrijven hoe je je in het algemeen verdedigt tegen cyber aanvallen. Omschreven door de letters 'CIA' - die hier niet slaan op het Central Intelligence Agency.

De C staat voor Confidentiality, en dat zegt dat data op de juist manier vertrouwelijk gehouden moeten worden. Dit kan onder meer door encryptie of authorisatie-mechanismen.

De tweede letter uit het anagram is de I, en die slaat op Integrity. Dit princitpe geeft aan dat je de integriteit van je data op de voet moet volgen; met tools als version control, access control, security control, data logs of checksums.

Tot slot heb je de A die voor Availability staat; en dat slaat meer op de beschikbaarheid van data. Deze beschikbaarheid wordt gebruikt in de context van het vermijden van hardware crashes (mede te voorkomen door RAID te hanteren), geen DDOS aanvallen, etc.

MFA
Multi-Factor Authenticatie bestaat eruit dat de je je gaat autoriseren met verschillende 'factoren'. Deze kunnen uit 3 mogelijke categorieën komen. De meest gekende en voorkomende is iets dat je 'weet', bijvoorbeeld een paswoord en username. De tweede optie is om iets te refereren dan je 'hebt'; bijvoorbeeld een smartphone of internet banking device. De laatste factor is misschien de meest geavanceerde, en kijkt naar iets dat je 'bent'. Voorbeelden hiervan zijn een irisscan of stemherkenning.

Als je er als applicatie voor wil zorgen dan je gebruikers zo veilig mogelijk kunnen inloggen vereis je best een combinatie van verschillende van deze factoren. Zo is er bijvoorbeeld de app 'Itsme' om de gsm als factor ter beschikking te stellen wanneer je online met een paswoord en username inlogt. In een ander voorbeeld wordt cryptocurrency vaak opgeslagen op een fysieke harde schijf waarbij je dan ook nog eens een paswoord nodig hebt.

Attack vectors
Vervolgens kwamen meest voorkomende en gevaarlijke actuele attack vectors aan bod.

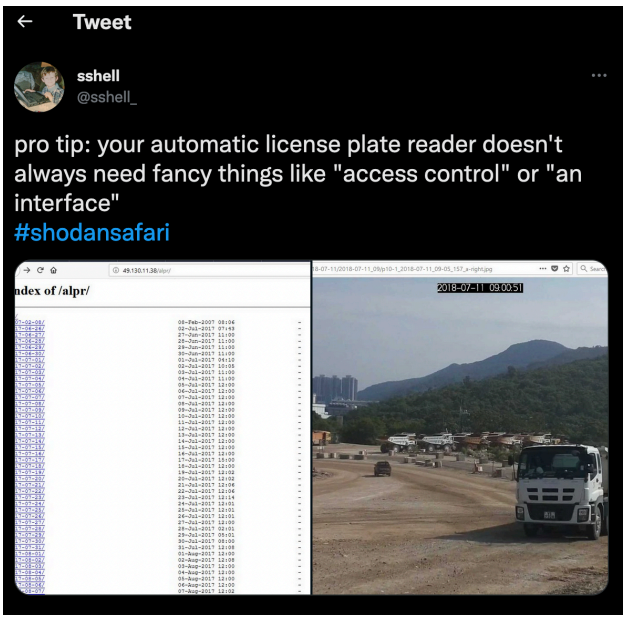
De eerste vector die werd aangehaald was ransomware. Het gebeurt tegenwoordig regelmatig dat hackers via malafide software bestanden bv versleutelen of stelen; en hier dan vervolgens een ransom (losgeld) voor vragen. Deze software wordt onder meer verspreid via virussen als Trojaanse paarden of via corrupte URL's.

Dan werden de gevaren van het IoT aangekaart. Heel veel toestellen die voor hun slimme features met het internet verbonden zijn, blijken onvoldoende beveiligd tot gewoon onprofessioneel opgezet wat betreft de data die ze ter beschikking stellen. Zo stelt bijvoorbeeld een 'slimme' waterketel de credentials van het wifi netwerk ter beschikking; of kan je de locatie van bepaalde toestellen lezen.

Wat als een aparte categorie te vermelden valt, zijn de toestellen die wanneer ze 'gehackt' zijn gebruikt kunnen worden om te spioneren. Tegenwoordig zijn er heel veel beveiligingscamera's aangesloten op het netwerk, net als geluids- en andere sensoren; en als je in deze toestellen kan inbreken kan je op die manier mensen in het oog houden.

Hier kwam ook de site Shoran aan bod, een ‘Google voor IoT’ waar je allerlei toestellen kan terugvinden aan de hand van bijvoorbeeld IP, locatie of hostname.

Een interessant voorbeeld hiervan vond ik op de twitter-feed die Pieter aanraadde. Het betreft een



camera die automatisch nummerplaten leest; vermoedelijk om die data dan bij te houden en te analiseren. Maar dit toestel werd dus gekraakt, en nu kan je on-site live meekijken alsook de nummerplaten meelezen.

IAM Hack

Het letterwoord IAM staat voor Identity and Access Management; en gaat eigenlijk over de toegang tot effectieve hardware (pc, laptops veelal). Er zijn namelijk manieren om de vele beveiligingen die OS’en inbouwen te omzeilen, en daar is een constant kat- en muisspel gaande waarbij die bedrijven en communities (met als grote spelers windows, mac en linux) gaten in de security proberen dichten terwijl de hackers die fixes weer proberen te omzeilen.

Iris toonde in detail hoe zo’n IAM aanval er anno 2022 een kan uitzien op een (gestolen) windows computer. De drie verdedigingslagen die je als hacker zal moeten omzeilen zijn het paswoord, de anti-virus en zaken als bitlocker en anti-virus. Dat laatste kwam hier niet aan bod.

Om het paswoord te omzeilen is het belangrijk om offline in te loggen. Je doet dit met een officiële windows versie (op schijf of USB) via secure boot; en zo geraak je via het obscure ‘prepare your computer’ in de command prompt. Dan ben je klaar om de standaard windows programma’s die in de windows folder staat - en steeds beschikbaar zijn - te hacken.

Dit ‘hacken’ is in de kern gewoon het hernoemen van dergelijke programma’s die standaard beschikbaar zijn. De programma’s die onder vuur genomen werden zijn ten eerste de anti-virus programma’s (offline en in de cloud) en vervolgens wordt de ‘sticky-keys’ exe vervangen door de command prompt. Nu kan je opstarten en de command prompt openen in local system context. Dit zorgt ervoor dat je een account kan maken met de nodige rechten.

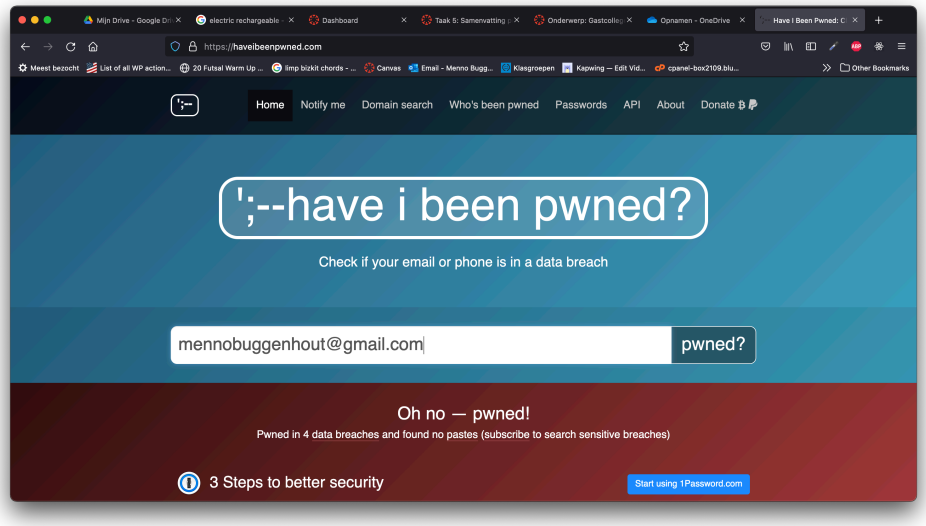
Nog een laatste stap die dan moet gebeuren zorgt er voor dat je remote kan gaan inloggen op die nieuwe account. Ook weer via de command prompt zet je de firewall af, de nodige poorten open en je verandert de system registry zodat remote access mogelijk wordt. Nu ben je ingelogd en kan je aan de computer.

Deze attack vector is heel moeilijk te beveiligen vanuit het standpunt van een OS, want het is heel belangrijk voor hen om ‘Ease of Access’ aan te bieden en hiervoor moet de computer opstarten in een ‘local system’ context.

Social Engineering
Tot slot werd er ingezoomd op de grootste kwetsbaarheid van elk systeem: de menselijke factor. Dit kan gaan van groots opgezette acties waarbij goed georganiseerde hackers semi-legitieme callcenters opzetten -die dan misbruikt kunnen worden naar believen wanneer ze bijvoorbeeld toegang krijgen tot gegevens van klanten - tot kleinere individuele acties.

Zo kan iemand zich voordien als onderhoudspersoneel en toegang krijgen tot plaatsen die normaal gezien beveiligd zouden moeten zijn, of je zorgt er op één of andere manier voor dat mensen een malafide usb-stick vertrouwen, invoeren en zo corrupte software activeren.

Conclusie
Ik vond de lezing zeer interessant. Het waren bevlogen sprekers en ze hadden een grote kennis van zaken. Ze hadden vele interessante anekdotes die recht uit de praktijk kwamen en tot de verbeelding spraken. Ik denk dat ook dat er mij veel van gaat bijblijven.

Ook handig zijn de tools die bedoeld zijn voor developers om de bedreigingen grondig te leren kennen. Zo is er Google-gruyère, dat kwetsbaarheden van apps simuleert; en verder heb je Hackthebox en Vulnhub, waar je kan proberen om in een begeleide omgeving virtuele machines en IoT apparaten te kraken.

En oh ja, ook ik bleek gebreached…